

☒ 1. Data Extraction

Definition:

The act of retrieving sensitive data from a web application by exploiting vulnerabilities.

Key vectors used:

- SQL Injection (SQLi)
- Directory traversal
- Insecure direct object references (IDOR)
- Broken access control
- Server-side template injection (SSTI)

Example:

An attacker uses SQLi to extract usernames and passwords from a database.

Mitigations:

- Input validation
- Parameterized queries
- Least privilege access
- Monitoring and logging

Related OWASP Top 10 risks:

- A01:2021 – Broken Access Control
 - A03:2021 – Injection
 - A05:2021 – Security Misconfiguration
-

☒ Tools Used for Data Extraction:

- SQLMap
 - Burp Suite (Intruder, Repeater, Scanner)
 - Hydra (for brute-forcing)
 - Manual exploitation via intercepting proxies
-

☒ 2. Advanced Identification and Exploitation

Definition:

Advanced techniques used to identify and exploit vulnerabilities beyond basic scans, often used in manual or semi-automated penetration tests.

Common techniques:

- Business logic attacks
- Chained exploits (e.g., bypass WAF + SQLi)
- Authentication/authorization bypass
- LFI/RFI exploitation
- File upload bypass & remote code execution (RCE)

Real-world example:

Using Burp Intruder to fuzz parameters, identify a file upload bypass, then chaining it to gain RCE.

Mitigations:

- Secure coding practices
- Security testing (SAST, DAST, IAST)
- Bug bounty programs
- Strong input validation & sanitization

Related OWASP Top 10 risks:

-

A05:2021 – Security Misconfiguration

-

A07:2021 – Identification and Authentication Failures

-

A09:2021 – Security Logging and Monitoring Failures